Tech Challenge - Fase 1

Nome do Grupo: Capitão Américo
Participante: Arturo Américo
Discord Username: tuco0448
Link do do repositório: https://github.com/SirBartolomeu/oficina-mvp
Link da documentação:https://github.com/SirBartolomeu/oficina-mvp/tree/main/docs

---

Relatório de Vulnerabilidades

1. Contexto da Execução

Data/Hora (UTC): 03/05/2026 – 13:58
Máquina: arturo-pc
Usuário: arturo
Branch: N/A
Commit: N/A

---

2. Ferramentas Utilizadas

- .NET SDK: 9.0.301
- Python: 3.11.9
- Docker: 29.4.0
- Semgrep: 1.161.0
- Docker Scout: v1.20.4

---

3. Resumo do Resultado

Ferramenta	Critical	High	Medium	Low	Total
dotnet-nuget	0	4	0	0	4
semgrep	0	1	0	0	1
docker-scout	0	0	2	27	29
TOTAL	**0**	**5**	**2**	**27**	**34**

---

4. Achados Consolidados

Alta Severidade (HIGH)

Dependências .NET (NuGet)

Vulnerabilidade: GHSA-7jgj-8wvc-jh57

- Pacote: System.Net.Http
- Localizações:
  - tests/OficinaMvp.Domain.Tests
  - tests/OficinaMvp.Integration.Tests
- Referência: https://github.com/advisories/GHSA-7jgj-8wvc-jh57

Vulnerabilidade: GHSA-cmhx-cq75-c4mj

- Pacote: System.Text.RegularExpressions
- Localizações:
  - tests/OficinaMvp.Domain.Tests
  - tests/OficinaMvp.Integration.Tests
- Referência: https://github.com/advisories/GHSA-cmhx-cq75-c4mj

---

Dockerfile (Semgrep)

Regra: execução como root

- Arquivo: src/OficinaMvp.Api/Dockerfile (linha 20)

Risco:
Container rodando como root pode permitir controle total em caso de exploração.

Recomendação:
Definir usuário não privilegiado com `USER`.

Média Severidade (MEDIUM)

Container Image (Docker Scout)

CVE-2025-45582

- Pacote: tar
- Status: sem correção disponível

CVE-2026-41989

- Pacote: libgcrypt20
- Status: sem correção disponível

Baixa Severidade (LOW)

Container Image – Vulnerabilidades Legadas

Foram identificadas **27 vulnerabilidades de baixa severidade**, majoritariamente relacionadas a bibliotecas base do sistema:

Principais pacotes afetados:

- glibc
- systemd
- openssl
- libgcrypt
- coreutils
- perl
- Apt
-

Observações importantes:

- Muitas vulnerabilidades são antigas (2005–2025)
- Grande parte sem exploit ativo relevante
- Sem patch disponível no momento

Resumo Técnico

- **Total de vulnerabilidades:** 34
- **Alta prioridade:** 5
- **Risco dominante:** Dependências e configuração de container
- **Maior concentração:** imagem base Docker

---

5. Recomendações

1. Corrigir imediatamente vulnerabilidades **High**
2. Atualizar dependências NuGet afetadas
3. Ajustar Dockerfile para execução segura (não-root)
4. Reexecutar scans após correções
5. Manter pipeline de segurança contínuo

---

6. Limitações

- Representa o estado no momento do scan
- Não garante ausência total de vulnerabilidades
- Deve ser complementado com testes manuais

---

7. Evidências Brutas

Local: `security-report/raw/`

- metadata.json
- dotnet-vulnerabilities.json
- semgrep.json
- docker-scout-cves.sarif.json